

Script-Controlled ACL: Restrict Record Access Based on Field Value

Project Description:

This project demonstrates how to implement a **script-controlled Access Control List (ACL)** in ServiceNow to restrict users from viewing records unless they meet specific conditions. In the scenario, only users who belong to the **EEE branch** may view records whose **Branch field is set to EEE**, while administrators retain full access.

The solution builds the EEE User and four custom roles (bb1, bb2, bb3, bb4), a custom table called Institution Details (u_institution_details), and four ACLs: a script-controlled READ ACL with a Branch is EEE data condition, and CREATE, WRITE and DELETE ACLs that each require one role. Each ACL is verified by impersonating the EEE User and the Administrator. Estimated time to complete the lab: 3 hours.

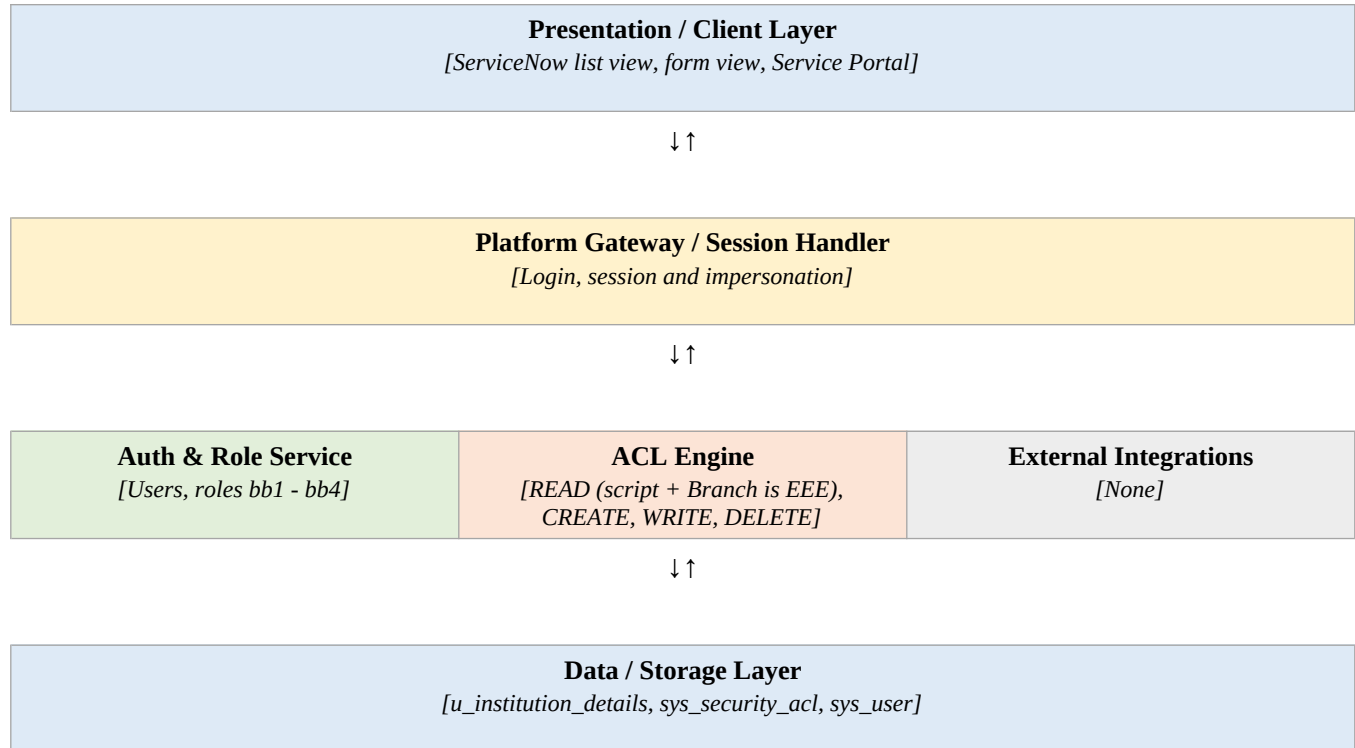
Scenarios

Scenario 1: The EEE User, who holds role bb1, opens the Institution Details list. The READ ACL evaluates the Branch is EEE condition and the script, so only the EEE branch records are shown and the ECE and CSE records stay hidden.

Scenario 2: A user who has none of the roles bb1 - bb4 opens the same list. No ACL grants access, so the user cannot view any records.

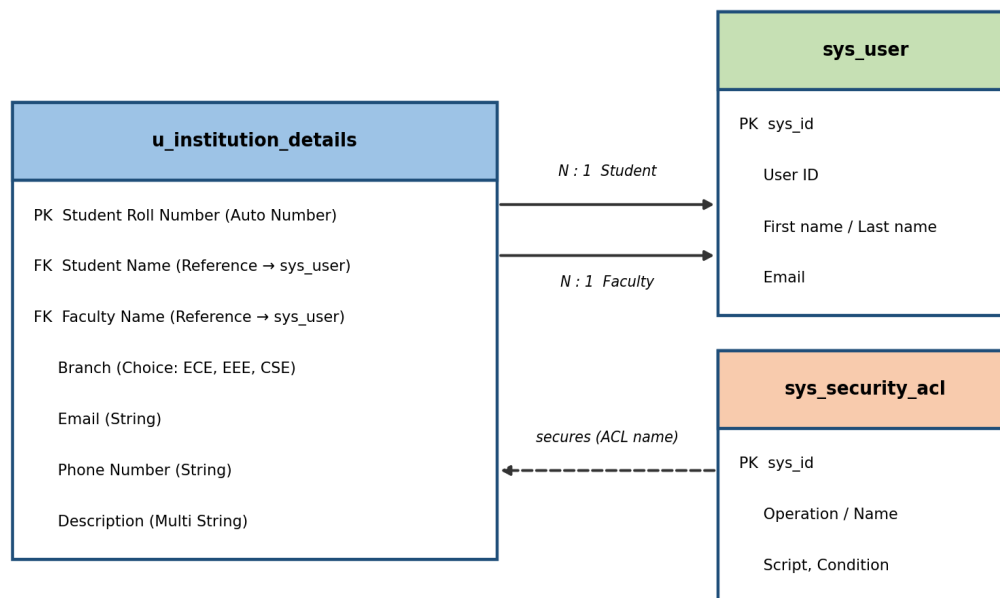
Scenario 3: An administrator opens the list. The ACL script returns true for `gs.hasRole('admin')`, so the administrator can view all records regardless of branch, and a user with bb1, bb2, bb3 and bb4 can also see the New button, edit and delete EEE records.

Technical Architecture:



Description: The solution uses a layered ServiceNow design. The browser-based UI sends every list and form request through the platform gateway, which identifies the user and the user's roles. The ACL engine then checks the matching ACL for the requested operation (read, create, write or delete), evaluates the role, the data condition Branch is EEE and the server-side script, and either returns the records or denies access. All records are stored in the custom table u_institution_details.

(Note: The project uses one custom table with reference fields to the User table. The ER diagram is shown below.)



Description: Each Institution Details record references one student and one faculty member from the sys_user table. The ACL records in sys_security_acl secure the table by name.

Pre-requisites:

- **ServiceNow Platform Knowledge:** ServiceNow Documentation (docs.servicenow.com)
- **ServiceNow Personal Developer Instance with admin access:** developer.servicenow.com
- **Access Control Lists (ACL) basics:** ServiceNow ACL documentation
- **Users, Roles and Tables:** User Administration and System Definition guides
- **JavaScript Basics:** W3Schools JavaScript Tutorial
- **Impersonation of users for testing:** ServiceNow impersonation documentation
- **Modern web browser:** Google Chrome or Microsoft Edge

Project Workflow:

Milestone 1: Creation of Users and Roles

- Activity 1.1: Log in with admin access and create the test user EEE User.
- Activity 1.2: Create the custom roles bb1, bb2, bb3 and bb4.
- Activity 1.3: Assign all the roles to the EEE User.

Milestone 2: Table Creation

- Activity 2.1: Create the custom table Institution Details (u_institution_details).
- Activity 2.2: Add the Student Roll Number, Student Name, Faculty Name, Branch, Email, Phone Number and Description fields.
- Activity 2.3: Create multiple records with Branch values ECE, EEE and CSE.

Milestone 3: Read ACL

- Activity 3.1: Elevate the security_admin role and create the READ ACL.
- Activity 3.2: Add the role bb1 and the data condition Branch is EEE.
- Activity 3.3: Add the ACL script and verify the result by impersonation.

Milestone 4: Create ACL

- Activity 4.1: Create the CREATE ACL that requires role bb2.
- Activity 4.2: Verify that the New button is available.

Milestone 5: Write ACL

- Activity 5.1: Create the WRITE ACL that requires role bb3.
- Activity 5.2: Verify that EEE records can be edited.

Milestone 6: Delete ACL

- Activity 6.1: Create the DELETE ACL that requires role bb4.
- Activity 6.2: Verify that EEE records can be deleted.

Milestone 1: Creation of Users and Roles

In this milestone, we prepare the people and permissions for the lab. A test user is created, and four custom roles are created and assigned to that user so that every ACL in the later milestones can be tested.

Activity 1.1: Create a Test User

1. Log in to the ServiceNow instance with admin access.
2. Navigate to **User Administration** → **Users** and click **New**.
3. Enter **User ID:** EEE User, **First name:** EEE, **Last name:** User, **Email:** eeeuser@gmail.com.
4. Save the record.

[Insert screenshot: New User form for EEE User]

Activity 1.2: Create the Roles

1. Navigate to **User Administration** → **Roles** and click **New**.
2. Enter **Name:** bb1 and a brief description of the role purpose.
3. Click **Submit**.
4. Create the other roles bb2, bb3 and bb4 by following the same procedure.

[Insert screenshot: Roles list showing bb1, bb2, bb3 and bb4]

Activity 1.3: Assign the Roles to the EEE User

- Open the EEE User record and use the **Roles** related list to add bb1, bb2, bb3 and bb4.
- Save the user record.

[Insert screenshot: EEE User roles related list]

Milestone 2: Table Creation

Milestone 2 creates the data that the ACLs will protect: a custom table with the fields needed to describe a student and a set of sample records with different branches.

Activity 2.1: Create the Custom Table

1. In the **Application Navigator**, search for **System Definition** → **Tables**.
2. Click **New** and enter **Label:** Institution Details and **Name:** u_institution_details. Keep Extends table as false (none).
3. Click **Submit**.

[Insert screenshot: Table creation form]

Activity 2.2: Add the Fields

Add the following fields to the u_institution_details table:

S.No	Field Name	Type
1	Student Roll Number	Auto Number
2	Student Name	Reference (User)
3	Faculty Name	Reference (User)
4	Branch	Choice (ECE, EEE, CSE)
5	Email	String
6	Phone Number	String
7	Description	Multi String

Save the table.

[Insert screenshot: Table columns]

Activity 2.3: Create Sample Records

- Create multiple records in the Institution Details table with different Branch values (ECE, EEE, CSE).

[Insert screenshot: Institution Details list with sample records]

Milestone 3: Creation of Access Control Lists (Read ACL)

Milestone 3 creates the script-controlled READ ACL, which is the core of the project. It decides who may view records of the Institution Details table.

Activity 3.1: Create the READ ACL

1. In the **Application Navigator**, search for **System Security** → **Access Control (ACL)**.
2. Elevate the **security_admin** role.
3. Click **New** to create a new ACL.
4. Enter **Type:** record, **Operation:** read, **Name:** u_institution_details, **Active:** true, **Advanced:** true.

[Insert screenshot: New ACL form with read operation]

Activity 3.2: Add the Role and Data Condition

- In the **Requires role** related list, add the custom role **bb1**.
- Add the data condition **Branch is EEE**.

Activity 3.3: Add the ACL Script

In the **Script** field, add the following script and click **Submit**:

```
(function () {  
  
    // Allow admin users full access  
    if (gs.hasRole('admin')) {  
        return true;  
    }  
  
    // Allow only EEE branch users to see EEE records  
    if (gs.hasRole('bb1')){  
        return true;  
    }  
  
    // Deny access for all others  
    return false;  
  
})();
```

Activity 3.4: Verify the Read ACL

1. Impersonate the **EEE User** and open the Institution Details list (type u_institution_details.list in the application navigator filter).
2. Impersonate the **Admin** and open the same list.

Expected results:

- A user with the **bb1 role** can view **only EEE branch records**.
- A user without the role cannot view any records.
- The Admin user can view **all records regardless of branch**.

[Insert screenshot: EEE User list view showing only EEE records]

[Insert screenshot: Admin list view showing all records]

Milestone 4: Creation of Access Control Lists (Create ACL)

Milestone 4 controls who can create new records. The CREATE ACL requires role bb2 and has no data condition.

Activity 4.1: Create the CREATE ACL

1. Click **New** to create a new ACL (Create).
2. Enter **Type:** record, **Operation:** create, **Name:** u_institution_details, **Active:** true.
3. In the **Requires role** related list, add the custom role **bb2**.
4. Do not add any data condition and save the ACL record.

[Insert screenshot: Create ACL record]

Activity 4.2: Verify

- A user with the **bb1 and bb2 roles** can view the EEE branch records and sees the **New** button.

[Insert screenshot: List view showing the New button]

Milestone 5: Creation of Access Control Lists (Write ACL)

Milestone 5 controls who can edit records. The WRITE ACL requires role bb3.

Activity 5.1: Create the WRITE ACL

1. Click **New** to create a new ACL (Write).
2. Enter **Type:** record, **Operation:** write, **Name:** u_institution_details, **Active:** true.
3. In the **Requires role** related list, add the custom role **bb3**.
4. Do not add any data condition and save the ACL record.

[Insert screenshot: Write ACL record]

Activity 5.2: Verify

- A user with the **bb1, bb2 and bb3 roles** can view and edit the EEE branch records along with the New button.

Milestone 6: Creation of Access Control Lists (Delete ACL)

Milestone 6 controls who can delete records. The DELETE ACL requires role bb4.

Activity 6.1: Create the DELETE ACL

1. Click **New** to create a new ACL (Delete).
2. Enter **Type:** record, **Operation:** delete, **Name:** u_institution_details, **Active:** true.
3. In the **Requires role** related list, add the custom role **bb4**.
4. Do not add any data condition and save the ACL record.

[Insert screenshot: Delete ACL record]

Activity 6.2: Verify

- Users with the **bb1, bb2, bb3 and bb4 roles** can see, create and edit, along with deleting, the **EEE branch records**.

[Insert screenshot: Record with the delete option available]

Final Output

The final result shows the script-controlled ACLs enforcing record-level security on the Institution Details table for each operation.

User	What the user can do
Admin	View all records regardless of branch
EEE User with bb1	View only EEE branch records
EEE User with bb1 + bb2	View EEE records and use the New button
EEE User with bb1 + bb2 + bb3	View, create and edit EEE records
EEE User with bb1 + bb2 + bb3 + bb4	View, create, edit and delete EEE records
User without the roles	Cannot view any records
[Insert screenshot: Final output: EEE User list view]	

Outcome

By completing this lab, learners gain a comprehensive understanding of how script-controlled READ, WRITE, CREATE, and DELETE ACLs enforce record-level security, how user roles and record field values are evaluated together to make access decisions, and how ACLs protect sensitive data from unauthorized viewing, modification, creation, and deletion across forms, lists, and Service Portal interfaces.